

Security+ 5.2 · Risk Analysis

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.2 — Risk Analysis (9:13) · [vídeo original ↗](#)
· [YouTube ↗](#)

Análise: qualitativa (alto/médio/baixo) vs quantitativa ($\$ — SLE \times ARO = ALE$); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

Highlights que a prova cobra

- $ALE = SLE$ (perda por incidente) $\times$ ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

Dicas de prova

- 'accepting a specific risk level per business unit' = risk tolerance

Cenário clássico: 'perda por incidente de \$500k $\times$ 2/ano = ALE de \$1M/ano' — quantitativo.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. RTO (Recovery Time Objective) mede:

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

2. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....

6. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...

8. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...

9. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo...

GABARITO COMENTADO

- 1) B — Quanto TEMPO o serviço pode ficar fora.** RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).
- 2) A — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO$ (vez. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo. As demais alternativas configuram violações graves**
- 3) A — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: v.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área (operacional). As demais alternativas configuram violações g
- 4) B — Implementar a solução correspondente: 'accepting a specific risk level per busin.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance. As demais alternativas configuram violações graves
- 5) D — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = AL.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.. As demais alternativas configuram violações gr
- 6) A — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO$ (vez. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo. As demais alternativas configuram violações graves**
- 7) D — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: v.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área (operacional). As demais alternativas configuram violações g
- 8) D — Implementar a solução correspondente: 'accepting a specific risk level per busin.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance. As demais alternativas configuram violações graves
- 9) A — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = AL.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.. As demais alternativas configuram violações gr
- 10) D — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO$ (vez. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo. As demais alternativas configuram violações graves**

